HTTP Desync Conformance Audit: Sample Report

SanFire OPC Pvt Ltd | REDACTED SAMPLE: client name, hosts and config paths removed. Findings below are from a stock lab chain, not a customer system.

Chain	Edge: nginx 1.28.3, default `proxy_pass` → Origin: ASP.NET Core Kestrel (pinned)
Method	Static, offline source review of both pinned trees against 25 RFC 9110/9112 framing rules. No traffic sent to any live system.
Client	[REDACTED]
Evidence pack	Rule set sealed before scoring; sha256-frozen; score not edited after independent skeptic review.

Verdict

HARDENING-REQUIRED	25 rules | 0 HIGH | 1 MEDIUM | 24 LOW | 0 NEEDS-LIVE

Finding R13-OWS-HTAB (MEDIUM)

nginx 1.28.3 keeps a leading or trailing HTAB in a header field value, and default `proxy_pass` copies that value to the origin. Kestrel treats HTAB as optional whitespace and trims it, so the two tiers extract different values from the same header. Any security decision made at the edge on such a value (routing, auth or allow-listing) can be evaluated on a different string than the one the app sees. Affects field values other than Host, Content-Length and Transfer-Encoding.

Source references: `ngx_http_parse.c` L972-975, 988-991, 1028-1030; `ngx_http_proxy_module.c` L1549-1556, 3936-3937.

Hardening (H13)

The pinned nginx tree has no parser directive that makes the two extractions match. Either stop forwarding the client header set where it is not needed (`proxy_pass_request_headers off`), or move any decision that uses the affected value to the origin, after Kestrel has trimmed it. The retest confirms the control.

Rows reviewed and not raised (examples)

Rule	Why it is LOW on this chain
R18 CL + TE	nginx rejects a request carrying both length fields with 400 before forwarding; RFC 9112 §6.1 allows this.
R19 TE on HTTP/1.0	nginx answers 400 first. Control H19 applies only if the origin is reachable without nginx.
R22 chunk CRLF	Kestrel parses nginx's rebuilt body, not the client's chunk-size line.
Body framing	Default proxy_pass writes a new request line and replaces Content-Length and Transfer-Encoding before the origin parses.

For comparison: the same 25 rules on stock HAProxy 3.4.7 (`mode http`) in front of Kestrel rate **GO**, 0 HIGH, 0 MEDIUM. HAProxy trims HTAB, so R13 does not carry over.

What a full engagement delivers

The 25-rule map pinned to your exact edge and .NET versions; GO / HARDENING-REQUIRED verdict with severities; a hardening checklist with exact config lines; the PDF report; a sha256-frozen evidence pack; one retest within 30 days. Written delivery only, within 5 business days of scope.

Public, reproducible source for this sample: github.com/realmpastai-web/flakecert (desync-oracle/). Contact: Santhosh Madhava, Managing Director, SanFire OPC Pvt Ltd, santhoshmadhava@sanfire.in